

Nachmittag 2 – Identify

Das KMU-Risikoprofil

Assets erfassen, Daten klassifizieren, Risiken bewerten – inkl. Lieferkette

Dauer	55–60 Minuten (inkl. 10 Min. Ergebnisdiskussion im Plenum)
Arbeitsform	Gruppen à 3–4 Personen
Material	Dieses Arbeitsblatt; Ergebnisse aus Übung 1 (Standortbestimmung)
NIST-CSF-Bezug	Identify: ID.AM (Asset Management), ID.RA (Risk Assessment); Govern: GV.SC (Lieferkette)

Lernziele

- Ein pragmatisches Asset-Inventar für ein KMU aufbauen (Systeme, Daten, Prozesse).
- Daten nach Schutzbedarf klassifizieren und daraus Anforderungen ableiten.
- Risiken mit Eintrittswahrscheinlichkeit und Auswirkung bewerten und in einer Matrix priorisieren.
- Lieferketten-Abhängigkeiten als eigenständige Risikoquelle erkennen.

Ausgangslage

Fallstudie: Muster Metallbau AG (fiktives KMU, 45 Mitarbeitende)

Die Muster Metallbau AG begleitet Sie durch alle Übungen dieses Workshops. Details siehe Steckbrief aus Nachmittag 1 – hier die Kurzfassung:

- Branche & Tätigkeit: Metallbau und Montage – Fertigung in eigener Werkhalle plus Projektgeschäft bei Kunden vor Ort. Zusätzlich kleiner Webshop für Ersatzteile (extern gehostet).
- Mitarbeitende: 45 (30 Produktion/Montage, 15 Büro: Verkauf, Einkauf, Buchhaltung, Planung/CAD, Geschäftsleitung). Keine eigene IT-Stelle.
- IT-Landschaft: Microsoft 365 (E-Mail, Teams, SharePoint), lokales ERP-System (Aufträge, Lager, Fakturierung), 4 CAD-Arbeitsplätze, Dateiserver im Serverraum, ca. 20 Notebooks/PCs, 10 Firmen-Smartphones, WLAN für Büro und Werkhalle (ein gemeinsames Netz).
- IT-Betreuung: externer IT-Dienstleister „TechPartner GmbH“ mit Pauschalvertrag (8 Stunden/Monat, Reaktionszeit „best effort“).
- Sicherheits-Ausgangslage: keine dokumentierten Richtlinien, kein MFA, alle Büro-Nutzer sind lokale Administratoren, Backup läuft nachts auf ein NAS im selben Serverraum (kein Restore-Test bekannt), Patching „wenn Zeit ist“.

Zusatzinformation für diese Übung: Die Muster AG speichert u. a.: Kundenstammdaten und Offerten, Konstruktionszeichnungen (CAD), Lohn- und Personaldaten, Lieferantenverträge, Zugangsdaten zum E-Banking sowie die Webshop-Bestellhistorie (Namen, Adressen, Bestellhistorie – Zahlung läuft über einen externen Zahlungsdienstleister).

Aufgabe A – Asset-Inventar (ca. 15 Min.)

Erfassen Sie die acht wichtigsten Assets der Muster AG. Ein Asset kann ein System, eine Datenart oder ein Geschäftsprozess sein. Bewerten Sie die Kritikalität aus Geschäftssicht: Wie lange kommt die Firma ohne dieses Asset aus bzw. was passiert, wenn es in falsche Hände gerät?

Asset (System / Daten / Prozess)	Typ	Verantwortlich (Owner)	Kritikalität (hoch / mittel / niedrig)	Warum? (1 Satz)

Aufgabe B – Datenklassifikation (ca. 10 Min.)

Ordnen Sie die folgenden Datenarten einer Klasse zu und notieren Sie die wichtigste Schutzanforderung. Klassen: Öffentlich – Intern – Vertraulich – Streng vertraulich.

Datenart	Klasse	Wichtigste Schutzanforderung
Produktkatalog und Website-Inhalte		
Konstruktionszeichnungen (CAD) für Grosskunden		
Lohn- und Personaldaten		
Kundenstammdaten und Offerten		
Interne Arbeitsanweisungen und Formulare		
E-Banking-Zugangsdaten		

Aufgabe C – Risikoanalyse (ca. 20 Min.)

Bewerten Sie die sechs Szenarien: Eintrittswahrscheinlichkeit (E) und Auswirkung (A) jeweils von 1 (sehr gering) bis 5 (sehr hoch). Risikowert = $E \times A$. Tragen Sie anschliessend die Szenario-Nummern in die Matrix ein.

Nr.	Szenario	E (1–5)	A (1–5)	$E \times A$	Begründung (Stichworte)
S1	Ransomware verschlüsselt ERP, Dateiserver und das NAS-Backup; Produktion und Fakturierung stehen still.				
S2	Phishing/CEO-Fraud: Buchhaltung überweist eine fünfstellige Summe auf ein Betrügerkonto.				
S3	Kompromittiertes M365-Konto: Angreifer liest E-Mails mit und versendet Schadmails an Kunden.				
S4	Ausfall des Webshop-Hosters oder Kompromittierung des Webshops (inkl. Kundendaten).				
S5	Der IT-Dienstleister TechPartner wird selbst gehackt; Angreifer nutzen dessen Fernzugriff auf die Muster AG.				
S6	Notebook eines Aussendienst-Mitarbeiters mit unverschlüsselten Kunden- und Offertdaten wird gestohlen.				

Risikomatrix (Szenario-Nummern eintragen)

	Auswirkung gering (1–2)	Auswirkung mittel (3)	Auswirkung hoch (4–5)
E hoch (4–5)			
E mittel (3)			
E gering (1–2)			

Priorisierung: Welche zwei Risiken würden Sie der Geschäftsleitung als „zuerst behandeln“ vorlegen?

Aufgabe D – Lieferkettenrisiken (ca. 10 Min.)

Die Muster AG hängt von mehreren externen Partnern ab. Notieren Sie pro Partner das grösste Risiko und die eine Frage, die die Geschäftsleitung diesem Partner als Nächstes stellen sollte.

Partner	Grösstes Risiko für die Muster AG	Die eine Frage an den Partner
TechPartner GmbH (IT-Dienstleister mit Fernzugriff)		
Webshop-Hoster		
ERP-Anbieter (Wartungsvertrag, Fernwartung)		
Microsoft 365 (Cloud)		

Diskussionsfragen fürs Plenum

- Welches Asset wurde in den Gruppen am häufigsten vergessen – und warum?
- Wo waren sich die Gruppen bei E × A uneinig? Was sagt das über Risikobewertung aus?
- Welche dieser Tabellen könnten Sie morgen 1:1 in Ihrem eigenen Unternehmen ausfüllen?